

SECURITY INCIDENT REPORT

Unauthorized Reconnaissance & SSH Brute Force Attack

Field	Details
Incident ID	IR-2026-0424-001
Date of Incident	April 24, 2026
Time of Incident	21:25 – 22:37 UTC
Date Reported	April 24, 2026
Analyst	Bryan Sykes
Severity	HIGH
Status	Closed — Simulated Lab Exercise
Detection Platform	Security Onion 2.4.211 (EVAL Mode)
Environment	Home Lab — VirtualBox / Oracle Linux 9.7

1. Executive Summary

On April 24, 2026, Security Onion detected a coordinated attack originating from an internal host at 192.168.1.209 targeting the Security Onion management node at 192.168.1.196. The attack consisted of two distinct phases: an active network reconnaissance phase using Nmap port scanning tools, followed by a credential brute force attack against the SSH service on port 22 using the Hydra password cracking tool.

Security Onion's Sigma detection engine generated 404 HIGH severity alerts documenting the SSH brute force campaign. Zeek network analysis logged 50 DNS queries associated with the attacker's activity. The attack was fully detected, logged, and contained within the lab environment. No credentials were compromised.

2. Severity Assessment

Category	Rating	Justification
Overall Severity	HIGH	Active brute force against SSH with 404 documented attempts
Confidentiality Impact	LOW	No credentials obtained — attack unsuccessful
Integrity Impact	LOW	No system modifications made
Availability Impact	LOW	No service disruption observed
Detection Confidence	HIGH	Fully logged by Sigma, Zeek, and Kibana

3. Incident Timeline

Time (UTC)	Event	Tool Used	Detection
21:24	Attacker initiates network ping sweep across 192.168.1.0/24 subnet — all live hosts enumerated including Security Onion at 192.168.1.196	Nmap -sn	Zeek conn.log
21:25	Aggressive port scan (-A -T4) launched against 192.168.1.196 — Port 22 (SSH/OpenSSH 8.7) identified as open, 999 ports filtered	Nmap -A -T4	Suricata / Zeek
21:26	Service version detection scan (-sV) confirms OpenSSH 8.7 on port 22	Nmap -sV	Zeek conn.log
21:27	OS fingerprinting scan (-O) executed — target identified as Linux-based system	Nmap -O	Zeek conn.log
22:33	SSH brute force campaign initiated using Hydra with rockyou.txt wordlist targeting root account on port 22	Hydra	Sigma — HIGH
22:34	404 SSH login failure alerts generated — attack ongoing	Hydra	Sigma — HIGH x404
22:37	Brute force campaign terminated — 0 valid credentials found	Hydra	Sigma — final alert 22:37:21Z

4. Technical Analysis

4.1 Phase 1 — Network Reconnaissance (Nmap)

The attacker conducted systematic network reconnaissance using four distinct Nmap scan types against the target environment:

Scan Type	Command	Findings
Ping Sweep	nmap -sn 192.168.1.0/24	Discovered all live hosts on subnet including target at 192.168.1.196
Aggressive Scan	nmap -A -T4 192.168.1.196	Identified Port 22 open running OpenSSH 8.7 — 999 ports filtered
Version Detection	nmap -sV --version-intensity 5 192.168.1.196	Confirmed OpenSSH 8.7 (protocol 2.0) on port 22
OS Detection	nmap -O 192.168.1.196	OS fingerprinted as Linux — kernel 4.15-5.19 (97% confidence)

Key reconnaissance findings visible to the attacker:

- SSH (port 22) — OPEN — OpenSSH 8.7 — primary attack vector identified
- 999 ports filtered — firewall actively blocking most services
- MAC Address: 08:00:27:C1:C3:8B (PCS Systemtechnik/Oracle VirtualBox NIC)
- Network Distance: 1 hop — target is on the same local network segment

4.2 Phase 2 — SSH Brute Force (Hydra)

Armed with reconnaissance data confirming SSH was accessible, the attacker launched a dictionary-based credential attack using Hydra with the rockyou.txt wordlist (14,344,392 passwords). The attack targeted the root account specifically.

```
hydra -l root -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.196 -t 4 -V -w 10
```

Parameter	Value	Meaning
-l root	root	Single username targeted — root account
-P rockyou.txt	14,344,392 passwords	Full rockyou wordlist used
-t 4	4 threads	4 parallel connection attempts
-w 10	10 second timeout	Wait time per attempt
Target	ssh://192.168.1.196:22	SSH service on Security Onion management IP
Result	0 valid credentials found	Attack unsuccessful — SSH hardened
Attempts Made	~340 before manual termination	Stopped by analyst during simulation

5. Indicators of Compromise (IOCs)

IOC Type	Value	Context
Source IP	192.168.1.209	Kali Linux attacker VM — origin of all malicious traffic
Target IP	192.168.1.196	Security Onion management node — attack target
Target Port	22 (TCP)	SSH service — brute force target
Target Service	OpenSSH 8.7	Service identified during reconnaissance
Username Targeted	root	Privileged account targeted by Hydra
Wordlist Used	rockyou.txt	Common dictionary attack wordlist
Tool — Recon	Nmap 7.95	Network reconnaissance tool
Tool — Attack	Hydra v9.5	Credential brute force tool
MAC Address	08:00:27:C1:C3:8B	Attacker VM NIC — VirtualBox virtual adapter
Attack Window	21:24 – 22:37 UTC	Total duration approximately 73 minutes

6. Detection Evidence

6.1 Security Onion Alerts (Sigma)

Rule Triggered: Security Onion - Grid Node Login Failure (SSH)

Detection Module: Sigma

Total Alerts Generated: 404

Severity Level: HIGH (severity score: 4)

First Alert Timestamp: 2026-04-24T22:33:00Z

Final Alert Timestamp: 2026-04-24T22:37:21Z

Source IP Confirmed: 192.168.1.209 (Kali Linux)

Destination IP Confirmed: 192.168.1.196 (Security Onion)

6.2 Zeek Network Analysis

Log Type: zeek.dns

Total Entries: 50 DNS query events

Source: 192.168.1.209

Significance: DNS activity logged from attacker IP during reconnaissance and attack phases

6.3 Kibana Log Evidence

Search Query: source.ip: 192.168.1.209

Results: Multiple log entries confirming attacker IP activity across timeframe

Timestamps Observed: 18:52 – 18:53 local time (April 24, 2026)

Log Sources: sigma.alert, zeek.dns, SOC event handler logs

7. Response Actions Taken

Action	Details	Outcome
Attack Simulation Terminated	Hydra brute force manually stopped after ~340 attempts	Attack traffic ceased
Alert Triage	All 404 Sigma alerts reviewed in SOC dashboard	Confirmed SSH brute force pattern
Log Analysis	Zeek DNS logs reviewed in Kibana	50 DNS entries attributed to attacker
IOC Collection	Source IP, destination IP, port, timestamps documented	Full IOC set captured
Evidence Preservation	Screenshots taken of all alert data, Kibana results, and Zeek logs	Documentation complete

8. Recommendations

Immediate Actions

- Block source IP 192.168.1.209 at perimeter firewall
- Review all SSH authentication logs for additional unauthorized attempts
- Audit all accounts for unauthorized access or privilege escalation

Short-Term Hardening

- Disable SSH password authentication — enforce key-based authentication only
- Implement fail2ban to automatically block IPs after repeated failed SSH attempts
- Restrict SSH access to specific trusted IP addresses via firewall allowlist
- Change SSH from default port 22 to a non-standard port to reduce automated scanning
- Disable root SSH login — require sudo escalation from non-privileged accounts

Long-Term Security Improvements

- Implement multi-factor authentication (MFA) for all remote access
- Deploy a jump host / bastion server for all SSH access
- Enable centralized log monitoring with alerting thresholds for failed login attempts
- Conduct regular vulnerability scans to identify exposed services
- Implement network segmentation to isolate management interfaces from user networks

9. Lessons Learned

Observation	Lesson
Nmap identified SSH as the only open port in under 15 seconds	Minimize attack surface — every open port is a potential entry point
Hydra attempted 340+ passwords before being manually stopped	Without fail2ban or rate limiting, brute force attacks can run indefinitely
Security Onion generated 404 alerts within minutes	Properly tuned IDS/IPS provides rapid detection of brute force campaigns
Zeek logged DNS activity throughout the attack	Network visibility at the protocol level captures attacker behavior beyond just alerts
Root account was targeted first	Privileged accounts are always primary targets — disable direct root login
PCAP capture was limited in bridged EVAL mode	Production deployments should use dedicated sniffing interfaces for full PCAP

10. Conclusion

This simulated attack exercise successfully demonstrated the full attack lifecycle from initial reconnaissance through active exploitation attempt, and validated Security Onion's detection capabilities across multiple log sources. The Sigma detection engine correctly identified and classified 404 SSH brute force events as HIGH severity. Zeek provided supplementary network visibility through DNS log correlation. Kibana enabled cross-source log investigation confirming the attacker's IP and activity timeline.

The exercise confirmed that Security Onion EVAL mode provides robust intrusion detection capabilities suitable for SOC analyst training and blue team skill development. All attack activity was fully contained within the lab environment with zero real-world impact.